

Chapitre 11

La maîtrise du risque d'externalisation — corrigés

Corrigé

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Corrigés des exercices du chapitre

Corrigé de l'exercice 1 — Les cinq catégories de risque et la non-transférabilité de la responsabilité

- (a) Risque de **conformité** : le prestataire de traitement des paiements d'une banque omet d'appliquer un embargo réglementaire sur certains pays, exposant la banque à une violation de sanctions internationales. Risque de **concentration** : trois des principaux prestataires informatiques d'une banque dépendent tous du même centre de données situé dans une seule zone géographique, si bien qu'un événement local unique (coupure électrique régionale) affecterait simultanément l'ensemble de ces prestataires. Risque **réputationnel** : un centre d'appels externalisé traite grossièrement des clients, et les plaintes qui en résultent, largement relayées, ternissent l'image de la banque alors même que celle-ci n'est pas directement en cause. Risque **pays** : un prestataire d'externalisation informatique situé dans un pays qui adopte soudainement des mesures de contrôle des capitaux ou d'instabilité politique majeure, compromettant la continuité du service fourni depuis ce pays. Risque **opérationnel** : une erreur humaine chez un prestataire de back-office (saisie erronée de masse) génère des milliers d'écritures comptables incorrectes chez la banque cliente, indépendamment de toute question de conformité, de concentration, de réputation ou de pays.
- (b) La phrase distingue *l'activité* — l'exécution matérielle et quotidienne des tâches (traiter des paiements, héberger des données, répondre aux clients) — de *la responsabilité* — l'obligation, qui incombe au conseil d'administration et à la direction générale, de garantir que cette activité, où qu'elle soit exécutée, demeure « conduite de manière saine et conforme à la réglementation ». L'activité peut être déléguée à un tiers ; la responsabilité, elle, reste attachée à l'établissement lui-même et à ses organes de gouvernance, quel que soit le degré d'externalisation retenu. Un établissement qui externaliserait entièrement une fonction, y compris sa supervision quotidienne, ne pourrait donc **pas** se prévaloir d'une défaillance du prestataire pour dégager sa propre responsabilité : le cours est explicite sur le fait que cette responsabilité « ne se sous-traite pas », ce qui signifie qu'aucune clause contractuelle ni aucun degré de délégation opérationnelle ne peut transférer au prestataire l'obligation ultime de l'établissement envers ses clients et son régulateur — seule l'exécution matérielle change de mains, jamais l'imputabilité finale.
- (c) Dans l'ordre chronologique naturel d'une relation d'externalisation : (1) **l'évaluation des risques** de l'activité envisagée, en amont de tout contact avec un prestataire particulier ; (2) **la diligence raisonnable et la sélection du prestataire**, une fois le principe de l'externalisation validé ; (3) les **clauses contractuelles**, négociées avec le prestataire retenu ; (4) la **revue des incitations de rémunération** intégrées à ce même contrat, qui conditionne le comportement du prestataire pendant toute la durée de la relation ; (5) la **surveillance continue** du prestataire, tout au long de l'exécution du contrat ; et (6) la **planification de la continuité d'activité**, qui anticipe le scénario où la relation prendrait fin de façon non maîtrisée. Un dispositif limité aux trois premiers piliers resterait incomplet car il couvrirait exclusivement la phase *d'entrée* dans la relation (évaluer, choisir, contracter) sans rien prévoir pour sa phase *de vie* (s'assurer que les incitations de rémunération ne poussent pas le prestataire à privilégier son propre intérêt au détriment de la qualité de service, surveiller que la performance promise est effectivement au rendez-vous) ni pour sa phase *de sortie* (que faire si le prestataire, pourtant correctement choisi au départ, vient à défaillir des années plus tard) : un bon choix initial de prestataire n'immunise ni contre sa dégradation progressive, ni contre sa défaillance future.
- (d) Le principe de proportionnalité ne s'applique pas de façon uniforme aux six piliers : certains d'entre eux, comme la diligence raisonnable, portent sur un jugement de fond (le prestataire est-il fiable, solvable, structurellement compétent ?) qui reste nécessaire quelle que soit la taille de l'établissement — un établissement de petite taille prend, en proportion de ses moyens, un risque tout aussi engageant à confier une fonction critique à un prestataire non vérifié qu'un grand établissement, de sorte que simplifier excessivement cet examen fait courir un risque de fond difficilement compressible. D'autres piliers, en revanche, comme la revue des incitations de rémunération, admettent plus aisément une version allégée : pour un établissement de petite taille recourant à « quelques prestataires réputés », une vérification ponctuelle que la structure

de rémunération n'incite pas à une dégradation de service peut suffire, alors qu'un établissement s'appuyant sur des centaines de prestataires devra probablement formaliser cette revue de façon systématique et répétée. La proportionnalité porte donc moins sur l'existence de chaque pilier, qui reste requise dans tous les cas, que sur l'intensité et le formalisme de sa mise en œuvre — une intensité qui se comprime plus facilement pour certains piliers (rémunération, formalisation de la surveillance) que pour d'autres (le jugement de fond porté par la diligence raisonnable).

Corrigé de l'exercice 2 — La diligence raisonnable et les clauses contractuelles

- (a) Le « risque de quatrième partie » désigne le risque que fait courir, non le prestataire directement engagé par l'établissement (la « troisième partie » par rapport au couple établissement-client), mais les propres sous-traitants de ce prestataire, situés un niveau plus loin dans la chaîne de fourniture. Il ne peut être capturé par l'examen de la réputation ou de la stratégie d'affaires du prestataire, qui porte sur son image et son positionnement propres, sans rien dire de la robustesse de ses propres relations de sous-traitance ; il ne peut pas davantage être capturé par le seul examen de sa situation financière, qui renseigne sur sa solvabilité mais pas sur la qualité de ses fournisseurs. Seul l'examen de « ses contrôles internes et opérationnels » permet de vérifier si le prestataire exerce lui-même « sa propre diligence sur ses sous-traitants » : c'est un contrôle de *processus* (le prestataire a-t-il un dispositif de sélection et de suivi de ses propres fournisseurs ?) et non un contrôle de *résultat financier ou réputationnel*, ce qui explique pourquoi seul le troisième axe de diligence raisonnable peut, par construction, révéler ce risque de rang supérieur.
- (b) Renseignent sur la capacité du prestataire à honorer le contrat *aujourd'hui* : les **états financiers récents** (photographie de la situation actuelle), la **liquidité** (capacité immédiate à faire face à ses obligations courantes) et les **résultats d'exploitation** (performance opérationnelle actuelle). Renseignent plutôt sur sa capacité à honorer le contrat *dans la durée* : la **solidité du capital** (coussin de résistance face à des chocs futurs), la **pérennité de l'activité** — explicitement définie par le cours à travers « l'ancienneté » et la « croissance de part de marché », deux indicateurs tournés vers la trajectoire du prestataire plutôt que vers son état présent —, l'**adéquation de la couverture d'assurance** (protection contre des sinistres futurs non encore survenus) et l'**engagement du prestataire, en ressources financières et humaines, à honorer le contrat sur toute sa durée** — qui, par construction, ne porte que sur l'avenir de la relation contractuelle et non sur sa situation actuelle.
- (c) Protègent principalement l'établissement en cours d'exécution normale du contrat : le **périmètre des responsabilités de chaque partie**, les **modalités de coût et de rémunération**, les **normes de performance mesurables**, les **exigences de confidentialité et de sécurité de l'information**, et les **conditions de propriété et de licence des données et logiciels** — autant de clauses qui structurent le fonctionnement quotidien de la relation tant qu'elle se déroule normalement. Ne prennent toute leur importance qu'en cas de dégradation ou de rupture de la relation : la **clause d'indemnisation**, les **conditions de défaut et de résiliation**, le **mécanisme de résolution des différends**, les **exigences d'assurance** (qui ne se matérialisent qu'en cas de sinistre) et le **plan de continuité d'activité du prestataire lui-même** (qui ne s'active qu'en cas de défaillance de ce dernier). Le **droit d'audit** relève des deux catégories à la fois : il s'exerce normalement de façon régulière et planifiée pendant l'exécution ordinaire du contrat (vérifier que les normes de performance et de sécurité sont respectées au fil de l'eau), mais il prend une importance accrue et souvent un caractère d'urgence précisément lorsqu'un doute survient sur la dégradation du service — c'est l'un des rares éléments contractuels dont l'utilité ne se limite pas à l'un des deux régimes.
- (d) Ces deux clauses répondent à un même risque structurel : celui d'une divulgation de données NPPI dont la gestion échapperait, en pratique, à tout cadre juridique clair et protecteur pour l'établissement. La clause de responsabilité conjointe établit *qui* répond d'une violation de données (l'établissement et son prestataire ensemble), mais elle ne dit rien de *sous quel droit* cette responsabilité conjointe serait concrètement mise en œuvre en cas de litige transfrontalier. Sans désignation explicite de la juridiction applicable, un tribunal étranger pourrait interpréter cette responsabilité conjointe « selon un droit local potentiellement moins protecteur » pour

les clients de l'établissement et pour l'établissement lui-même — par exemple en limitant les recours disponibles, en réduisant les obligations de notification, ou en interprétant différemment le partage de responsabilité entre les deux parties. L'absence de clause de juridiction aggrave donc spécifiquement la portée de la responsabilité conjointe car elle laisse son application dépendre d'un droit non choisi, potentiellement défavorable, au moment précis — une violation de données NPPI chez un prestataire étranger — où la protection juridique de l'établissement et de ses clients importe le plus.

Corrigé de l'exercice 3 — La surveillance continue et la planification de la continuité d'activité

- (a) Les « indicateurs de performance mesurables » et les « déclencheurs d'escalade » exercent deux fonctions distinctes et complémentaires : les premiers *mesurent* en continu un niveau de service (par exemple un taux de disponibilité ou un délai de traitement), tandis que les seconds *réagissent* à cette mesure en déclenchant une remontée hiérarchique lorsqu'un seuil de dégradation est franchi. Un indicateur de performance mesurable, à lui seul, ne fait qu'accumuler de la donnée : sans déclencheur d'escalade associé, rien ne garantit qu'une dégradation, même mesurée et documentée avec précision, remonte « rapidement [...] vers la direction » plutôt que de rester noyée dans un tableau de bord consulté tardivement ou superficiellement — l'indicateur informe, mais seul le déclencheur transforme cette information en action organisationnelle.
- (b) Parmi les quatre composantes du plan de continuité, c'est la **stratégie de sortie incluant un vivier de prestataires alternatifs comparables** qui suppose que l'établissement ait déjà, en amont, identifié et évalué d'autres prestataires potentiels : la sauvegarde des informations, l'articulation avec le propre plan de reprise après sinistre de l'établissement et les tests périodiques peuvent tous être organisés en interne ou avec le seul prestataire en place, alors qu'un « vivier de prestataires alternatifs comparables » exige, par définition, d'avoir mené une diligence raisonnable préalable sur des prestataires que l'établissement n'utilise pas encore. Cette composante rend le plan de continuité coûteux à maintenir même en l'absence de défaillance effective car elle impose de renouveler périodiquement, pour des prestataires qui ne sont pas rémunérés pour le service réellement fourni, l'ensemble du travail de diligence raisonnable (réputation, situation financière, contrôles internes) exigé à l'exercice 2 — un coût structurel d'option, payé chaque année, pour un scénario qui peut ne jamais se matérialiser.
- (c) Cette affirmation relativise fortement la portée du droit d'audit contractuel : un contrat qui prévoit un droit d'audit, mais dont ce droit ne serait jamais exercé, ne satisferait **pas** à l'exigence de ce chapitre. Le cours est explicite sur ce point — « aucun contrat, aussi bien rédigé soit-il, ne remplace une vérification active et continue » — ce qui signifie que la clause contractuelle n'est qu'une condition *nécessaire* (elle ouvre la possibilité juridique de l'audit) et non une condition *suffisante* (elle ne garantit en rien que l'établissement exerce effectivement, et avec une fréquence adaptée au risque du prestataire, ce droit qu'elle lui confère) : un droit d'audit purement formel, jamais mis en œuvre, équivaut en pratique à l'absence de toute surveillance, quelle que soit la qualité rédactionnelle du contrat qui le prévoit.
- (d) La synthèse en quatre temps couvre : « évaluer le risque en amont » (pilier 1, évaluation des risques), « exercer une diligence raisonnable rigoureuse sur le prestataire pressenti » (pilier 2, diligence raisonnable), « négocier un contrat qui couvre explicitement la performance, la sécurité, l'audit et la sortie » (pilier 3, clauses contractuelles), « surveiller la relation dans la durée avec une intensité proportionnée au risque » (pilier 5, surveillance continue) et « préparer activement le scénario où le prestataire ne pourrait plus honorer ses engagements » (pilier 6, planification de la continuité). Le pilier qui ne correspond explicitement à aucun des quatre temps cités est le **quatrième** : la **revue des incitations de rémunération intégrées au contrat**. Il s'y rattache implicitement au troisième temps de la synthèse, la négociation contractuelle : la structure de rémunération du prestataire fait partie intégrante de ce que la synthèse désigne, de façon compacte, comme « négocier un contrat qui couvre explicitement la performance » — une rémunération mal incitée (par exemple, un paiement forfaitaire indépendant du niveau de service réellement délivré) est précisément ce qui peut compromettre la « performance » que le contrat est censé garantir, de sorte que ce pilier, bien que non nommé séparément dans la

2 Corrigé de l'exercice cumulatif

Corrigé de l'exercice 4 — Le risque d'externalisation à la lumière des quatre chapitres précédents

- (a) Le recours par USAA à des sous-traitants « dont les qualifications n'avaient pas été vérifiées » est bien un cas d'école de ce que ce chapitre cherche à prévenir en amont : l'examen des « contrôles internes et opérationnels » du prestataire, « y compris [...] sa propre diligence sur ses sous-traitants », est précisément le dispositif qui, correctement appliqué *avant* l'engagement de ces sous-traitants, aurait dû révéler l'absence de vérification de leurs qualifications — la sanction du régulateur n'a fait que rendre visible *a posteriori*, sous forme de manquement sanctionné, ce que la diligence raisonnable de ce chapitre est conçue pour détecter *a priori*. Ce cadre, à lui seul, n'aurait toutefois probablement pas suffi à éviter la sanction dans son ensemble : le chapitre 10 précise que le régulateur a sanctionné « la qualité du dispositif de contrôle [...] non [...] des faits avérés de blanchiment », et documente par ailleurs un « département conformité [...] significativement sous-effectif » ainsi qu'un système de surveillance des transactions « trop sensible », générant un arriéré de « 90 000 alertes et 6 900 dossiers non examinés » — des défaillances de gouvernance interne et de surveillance qui dépassent le seul périmètre des sous-traitants et relèvent d'autres piliers de ce chapitre (évaluation des risques de l'activité, surveillance continue de la performance du dispositif dans son ensemble), voire de la propre organisation interne de la banque plutôt que de sa seule relation avec des tiers.
- (b) Ni l'un ni l'autre dispositif ne peut faire disparaître la loi locale de protection des données elle-même — ce constat est le point de départ nécessaire de la comparaison. Le chapitre 9 ne peut offrir, pour le partage d'information au sein d'un même groupe bancaire, qu'un principe de coordination interne (« la politique du groupe doit permettre à la succursale [...] d'adopter les exigences locales ») car chaque entité du groupe demeure, malgré l'unité de l'actionnariat, une personne morale distincte pleinement soumise au droit de sa propre juridiction : le groupe ne peut que *s'adapter* à cette pluralité de droits nationaux, non la contourner par un accord interne. Ce chapitre, confronté à un obstacle de même nature (une loi locale de protection des données) mais pour une relation avec un tiers externe, y répond par une clause contractuelle de désignation de juridiction qui ne résout pas davantage la question de fond de la conformité aux lois de protection des données applicables : elle détermine seulement *quel droit et quel tribunal* trancheront un éventuel litige contractuel entre l'établissement et son prestataire. Ce que chacun des deux dispositifs résout, en somme, n'est donc pas le respect de la loi locale elle-même — un respect qui s'impose dans les deux cas indépendamment de tout choix contractuel ou de politique de groupe —, mais *l'articulation prévisible* de la relation (intragroupe pour le chapitre 9, contractuelle avec un tiers pour ce chapitre) avec cette pluralité de droits : le chapitre 9 organise une flexibilité d'application interne au groupe, ce chapitre organise une prévisibilité de règlement des différends avec un tiers — deux réponses de nature différente à une même contrainte irréductible.
- (c) Si Equifax avait été un prestataire externe fournissant un service d'évaluation de crédit à une banque cliente, l'application du dispositif de surveillance de ce chapitre aurait dû permettre à cette banque cliente de détecter indépendamment au moins l'une des faiblesses du chapitre 8 : un audit type SOC 2, qui porte typiquement sur les contrôles de sécurité logique et la gestion des vulnérabilités du prestataire audité, aurait vraisemblablement révélé l'absence d'« inventaire exhaustif des actifs informatiques » qu'un tel audit cherche précisément à vérifier comme prérequis de toute gestion des correctifs ; de même, un indicateur de performance mesurable portant sur la disponibilité et l'intégrité de la supervision du trafic chiffré aurait pu signaler l'anomalie que représentait un « certificat SSL expiré [...] pendant des mois », sans même nécessiter de connaître par avance l'existence de la vulnérabilité Apache Struts elle-même. Une banque cliente qui n'exercerait son droit d'audit contractuel qu'une fois tous les trois ans n'aurait toutefois **pas** satisfait à l'exigence de « vérification active et continue » posée par ce chapitre : le

cas Equifax montre justement qu'une vulnérabilité connue le 7 mars a été exploitée dès le 10 mars et n'a été détectée en interne que le 29 juillet — un intervalle de quelques mois à peine, sans commune mesure avec un cycle d'audit triennal, qui aurait laissé la fenêtre d'exposition largement ouverte bien après le passage, tardif, d'un audit aussi espacé.

- (d) Les six catégories de risques du chapitre 7 (stratégique, de conformité, de sécurité, de continuité d'activité, de dépendance au prestataire, de concentration) recoupent les cinq catégories de ce chapitre (conformité, concentration, réputationnel, pays, opérationnel) sur exactement deux points explicitement nommés dans les deux chapitres : la **conformité** et la **concentration**. Le chapitre 7 nomme en outre un risque **stratégique**, un risque de **sécurité** et un risque de **dépendance au prestataire** sans équivalent explicitement nommé parmi les cinq catégories de ce chapitre — ce dernier les absorbe implicitement dans la catégorie plus large de risque « opérationnel » (« processus ou systèmes internes défaillants [...] ou événements externes et erreurs humaines ») sans les distinguer nommément comme le fait le chapitre 7 pour le cas cyber. Réciproquement, ce chapitre nomme un risque **réputationnel** et un risque **pays** sans équivalent explicitement nommé dans la liste du chapitre 7, qui se concentre sur des catégories directement pertinentes pour la gouvernance des tiers cyber et laisse ces deux dimensions, plus générales, hors de sa propre énumération. Deux éléments que ce chapitre détaille et que le chapitre 7 ne faisait qu'esquisser sans les nommer explicitement sont : la **revue des incitations de rémunération intégrées au contrat** (absente de l'énumération du chapitre 7, qui se limite à « un droit d'inspection et d'audit » sans traiter la structure de paiement elle-même) et la **stratégie de sortie assortie d'un vivier de prestataires alternatifs comparables** — le chapitre 7 mentionnait certes, pour un cas structurellement apparenté (la dépendance à un prestataire cloud unique, chapitre 3), la nécessité d'une « redondance », mais sans détailler, comme le fait ce chapitre, le dispositif concret de diligence raisonnable préalable sur des prestataires de repli identifiés à l'avance.

3 Corrigé des applications en sciences économiques

Corrigé de l'exercice 5 — Le risque de concentration des prestataires : mesurer l'exposition et vérifier la

On a cinq activités externalisées réparties entre trois prestataires : Nimbus (1 200 + 950 + 610), Voxa (430), Recoubank (260).

- (a) La dépense totale d'externalisation est $1\,200 + 950 + 430 + 610 + 260 = 3\,450$ k€. Nimbus concentre $1\,200 + 950 + 610 = 2\,760$ k€, soit une part de $2\,760/3\,450 = 80,0000\%$; Voxa concentre 430 k€, soit $430/3\,450 = 12,4638\%$; Recoubank concentre 260 k€, soit $260/3\,450 = 7,5362\%$ (les trois parts totalisent bien 100 %). Le plafond interne de 50 % par prestataire n'est **pas** respecté : Nimbus, à 80,00 %, le dépasse très largement, de 30 points.
- (b) L'indice HHI du portefeuille initial est $80,0000^2 + 12,4638^2 + 7,5362^2 = 6\,400,00 + 155,35 + 56,80 = 6\,612,14$. Ce chiffre dépasse très largement le seuil interne de 3 000 : le portefeuille de prestataires est bien, au sens de la politique interne de la banque, en situation de **concentration excessive** — un résultat cohérent avec la part de 80 % déjà identifiée en (a), un HHI proche de son maximum théorique de 10 000 (atteint pour un monopole total) signalant ici une dépendance quasi exclusive à un seul prestataire.
- (c) En retirant à Nimbus la surveillance cybersécurité (610 k€) au profit de SentinelSec, Nimbus ne concentre plus que $1\,200 + 950 = 2\,150$ k€, soit une part de $2\,150/3\,450 = 62,3188\%$; SentinelSec obtient une part de $610/3\,450 = 17,6812\%$. Le nouvel indice HHI, sur quatre prestataires, est $62,3188^2 + 12,4638^2 + 17,6812^2 + 7,5362^2 = 3\,883,64 + 155,35 + 312,62 + 56,80 = 4\,408,40$. Cette seule diversification **ne suffit pas** à ramener la part de Nimbus sous le plafond de 50 % : à 62,32 %, Nimbus reste au-dessus du seuil (bien qu'en net recul par rapport aux 80 % initiaux), et le HHI, bien qu'en forte baisse, reste lui aussi au-dessus du seuil d'alerte de 3 000. La banque devrait donc diversifier au moins une activité supplémentaire actuellement confiée à Nimbus (par exemple le traitement des paiements) pour ramener sa part sous le plafond interne.

- (d) Le montant sous-traité par Nimbus à son propre sous-traitant étranger est $0,25 \times 1\,200 = 300$ k€, soit une part de $300/3\,450 = 8,6957\%$ de la dépense totale du portefeuille. La combinaison du risque de quatrième partie avec le risque pays renforce la nécessité d'une clause de juridiction claire avec Nimbus lui-même car l'établissement n'a, par construction, *aucune relation contractuelle directe* avec ce sous-traitant de rang deux : en cas de défaillance ou de litige impliquant ce dernier, c'est exclusivement le contrat conclu avec Nimbus — et la juridiction qu'il désigne — qui déterminera comment la responsabilité se répercute jusqu'à l'établissement, une chaîne de recours d'autant plus fragile qu'elle traverse déjà une frontière (le sous-traitant étranger) avant même d'atteindre le prestataire directement engagé.

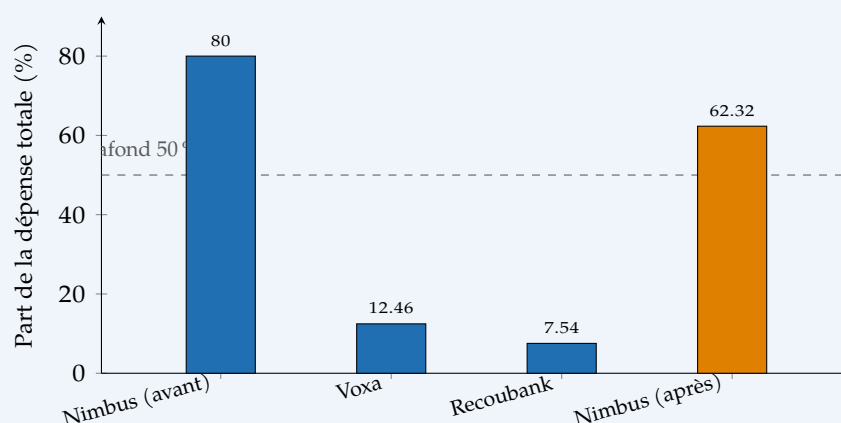


FIG. 1 : Part de chaque prestataire dans la dépense totale d'externalisation (en bleu, situation initiale; en orange, part de Nimbus après diversification de la surveillance cybersécurité vers SentinelSec) — exercice 5.

Corrigé de l'exercice 6 — Défaillance d'un prestataire critique : surveillance, escalade et vivier de prestataires

On a les deux indicateurs suivis sur quatre trimestres : résolution au premier contact (87, 82, 79, 76) et délai moyen (3,6; 4,3; 5,1; 5,8) heures, pour des seuils de 85 % et 4,0 heures respectivement.

- (a) Taux de résolution : T1 (87 %) respecte le seuil de 85 %; T2 (82 %), T3 (79 %) et T4 (76 %) le franchissent tous trois. Délai moyen : T1 (3,6 h) respecte le seuil de 4,0 h; T2 (4,3 h), T3 (5,1 h) et T4 (5,8 h) le franchissent tous trois. Pour les deux indicateurs, le déclencheur d'escalade (deux franchissements consécutifs) s'active à l'issue du **troisième trimestre (T3)** : T2 et T3 constituent la première paire de trimestres consécutifs à franchir simultanément chacun des deux seuils (T4 confirme, mais ne fait que prolonger, une dégradation déjà escaladée à l'issue de T3).
- (b) La pente trimestrielle du taux de résolution, entre T1 et T4 (trois intervalles), est $(76 - 87)/3 = -11/3 = -3,6667$ points par trimestre; celle du délai moyen est $(5,8 - 3,6)/3 = 2,2/3 = +0,7333$ heure par trimestre. En prolongeant cette tendance, la valeur projetée en T5, en l'absence de toute action corrective, serait de $76 - 3,6667 = 72,3333\%$ pour le taux de résolution et de $5,8 + 0,7333 = 6,5333$ heures pour le délai moyen — une poursuite de la dégradation sur les deux indicateurs simultanément.
- (c) La réduction du délai de détection permise par une surveillance mensuelle est $270 - 150 = 120$ jours. Au coût de 800 € par jour de dégradation non corrigée, l'économie ainsi permise est $120 \times 800 = 96\,000$ € : une surveillance mensuelle, réservée aux prestataires montrant des signes de dégradation comme l'exige le cours (« plus fréquente et plus stricte pour les prestataires à risque élevé ou montrant des signes de difficulté [...] »), aurait donc permis d'économiser 96 000 € sur ce seul épisode de dégradation, en confirmant le déclencheur d'escalade 120 jours plus tôt que la surveillance trimestrielle standard.
- (d) Le coût de transition par événement est $45 \times 12\,000 = 540\,000$ € sans vivier de prestataires alternatifs, contre $10 \times 12\,000 = 120\,000$ € avec vivier. Avec une probabilité annuelle de défaillance complète de 8 %, le coût annuel attendu **sans** vivier est $0,08 \times 540\,000 = 43\,200$ €; le coût annuel

attendu **avec** vivier, transition seule, est $0,08 \times 120\,000 = 9\,600$ €, auquel s'ajoute le coût annuel de maintien du vivier de 18 000 €, pour un coût total attendu avec vivier de $9\,600 + 18\,000 = 27\,600$ € par an. Le maintien du vivier est **justifié économiquement** : il réduit le coût annuel attendu de $43\,200 - 27\,600 = 15\,600$ € par an, pour un ratio bénéfice/coût de l'investissement de maintien du vivier (économie brute de transition de $43\,200 - 9\,600 = 33\,600$ € rapportée à son coût de 18 000 €) de $33\,600/18\,000 = 1,8667$ — chaque euro dépensé pour maintenir le vivier de prestataires alternatifs rapporte, en moyenne, près de 1,87 euro d'économie attendue sur le coût de transition en cas de défaillance complète du prestataire en place.

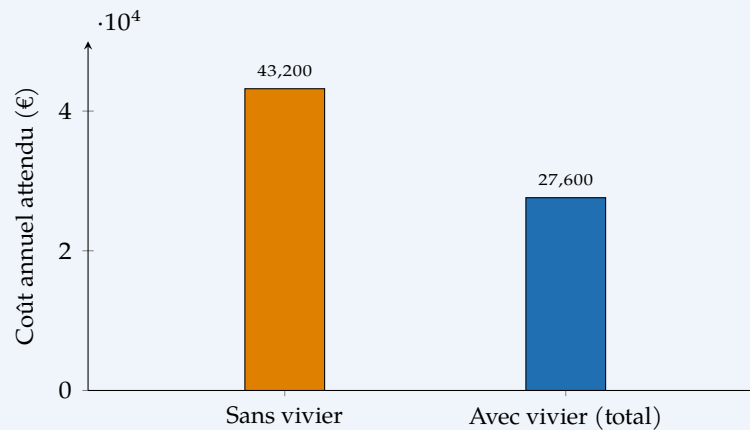


FIG. 2 : Coût annuel attendu d'une défaillance complète du prestataire, sans vivier de prestataires alternatifs (orange) et avec vivier, coût de maintien inclus (bleu) — exercice 6.